

SABOR & GESTIÓN

Informe Histórico de Errores, Bugs, Fallas de Seguridad y Correcciones

Documentación Técnico-Académica de Aseguramiento de Calidad y Refactorización

VERSIÓN DEL SISTEMA

1.0.0 (Producción Oficial)

MODELO ARQUITECTÓNICO

Monolito Multicapa Desacoplado (6 Capas)

INCIDENCIAS AUDITADAS

14 Incidencias Verificadas

FECHA DE PUBLICACIÓN

Septiembre de 2026

ESTADO DE AUDITORÍA

100% Corregido y Validado

ÁREA RESPONSABLE

Ingeniería de Software & QA

RESUMEN EJECUTIVO

El presente informe técnico-académico formaliza el exhaustivo proceso de detección, diagnóstico, corrección y endurecimiento ejecutado sobre el backend de Sabor & Gestión. A lo largo de su ciclo de evolución, el sistema transitó desde una fase con lógica dispersa, exposición de secretos y vulnerabilidades de manipulación de importes, hacia una arquitectura multicapa desacoplada y robusta.

Se catalogan y analizan catorce incidencias reales respaldadas por evidencia del repositorio, cubriendo la neutralización de credenciales expuestas, la erradicación del riesgo financiero mediante el principio de autoridad monetaria algorítmica en pedidos, la purga de módulos huérfanos y la imposición de un control de acceso basado en roles (RBAC) con mínimo privilegio.

La totalidad de las soluciones implementadas fueron sometidas a suites de pruebas de regresión automatizadas, consolidando un software altamente seguro, mantenible y preparado para la operación gastronómica en tiempo real.

TABLA DE CONTENIDOS

1. Fuentes de Información y Metodología

Evidencia documental, auditorías estáticas y ciclo de corrección

2. Clasificación de Incidencias y Criterios

Categorías de fallas y criterios objetivos de severidad

3. Registro Detallado de Incidencias

Catálogo de las 14 incidencias técnicas documentadas paso a paso

4. Auditoría de Seguridad y Autenticación

Hardening de secretos, JWT, sockets y prevención de borrado

5. Auditoría de Pedidos y Autoridad Monetaria

Snapshot histórico, prevención de manipulación de precios y validaciones

6. Auditoría del Ciclo de Vida de Mesas

Estados permitidos, transiciones atómicas y desacoplamiento

7. Retiro del Módulo de Reservas y Saneamiento

Justificación técnica, componentes purgados y verificación

8. Refactorización Arquitectónica Multicapa

Evolución a 6 capas, desacoplamiento y adelgazamiento de controladores

9. Endurecimiento de Validaciones Perimetrales

Técnica Fail-Fast, restricciones de esquema y normalización de errores

10. Control de Acceso Basado en Roles (RBAC)

Matriz estricta de privilegios mínimos por perfil operativo

11. Base de Datos y Consistencia Transaccional

Atomicidad en contadores e integridad referencial

12. Módulo de Pagos y Liquidación Financiera

Cálculos de descuentos, validación de montos y cierre de comanda

13. WebSockets y Comunicación en Tiempo Real

Autenticación en apretón de manos y sincronización sin recarga

14. Evidencia de Pruebas y Suites de Regresión

Cuadro de suites especializadas y resultados empíricos 100% superados

15. Cronología de Commits y Refactorizaciones

Hitos temporales y avances registrados en el repositorio

16. Tabla Resumen de Incidencias Catalogadas

Matriz consolidada con ID, severidad, impacto y estado

17. Análisis del Estado Actual del Backend

Condiciones actuales de estabilidad, seguridad y rendimiento

18. Conclusiones y Lecciones de Ingeniería

Balance técnico, principios aprendidos y recomendaciones

1. Fuentes de Información y Metodología

La información documentada en este informe técnico proviene exclusivamente de fuentes primarias y verificables del repositorio de software: historial Git de confirmaciones atómicas, diffs de código, suites de pruebas de integración especializadas y auditorías estáticas con TypeScript.

[Estado Problemático]	--> Detección de vulnerabilidad, fallo lógico o deuda técnica
%	
%%	
[Diagnóstico y Análisis]	--> Evaluación de impacto, causa raíz y superficie expuesta
%	
%%	
[Diseño de Corrección]	--> Refactorización arquitectónica sin alterar contratos válidos
%	
%%	
[Validación y Prueba]	--> Batería de regresión automatizada y verificación tsc
%	
%%	
[Estado Corregido]	--> Confirmación de cierre y consolidación en repositorio

2. Clasificación de Incidencias y Criterios

Las incidencias catalogadas se analizan bajo criterios objetivos de severidad:

- **Crítica:** Vulnerabilidades que permiten evasión de autenticación, fraude financiero o exposición pública de secretos.
- **Alta:** Riesgo de corrupción masiva de datos, ejecución de rutinas destructivas o intrusión horizontal de roles.
- **Media:** Desviaciones arquitectónicas, acoplamientos rígidos o estados zombi en máquinas de estado.
- **Baja:** Desajustes sintácticos menores en scripts o inconsistencias leves en esquemas secundarios.

3. Registro Detallado de Incidencias Catalogadas

INCIDENCIA 01 — Exposición de Credenciales Externas en Servicio de Correo	CRITICA
CATEGORÍA: A. Seguridad ESTADO: Corregido	
Descripción del Problema: En el servicio de correo electrónico, las credenciales del proveedor externo (identificadores de servicio, plantilla, usuario y token privado) estaban insertas como literales en el código fuente.	
Manifestación: Cualquier lector del código fuente obtenía acceso inmediato a la API externa de correo.	
Riesgo o Impacto: Uso no autorizado de la cuenta, suplantación institucional en envíos masivos y suspensión de la cuenta externa.	
Detección: Auditoría de seguridad estática durante la fase de hardening perimetral.	
Corrección Realizada: Extracción obligatoria a variables de entorno protegidas y verificación preventiva arrojando excepción si faltan.	
Verificación: Suite de seguridad (Bloque 1), validando la ausencia de credenciales en código y rechazo si faltan variables.	
Estado Actual: El servicio opera exclusivamente mediante variables de entorno validadas en el inicio del servidor.	

INCIDENCIA 02 — Credenciales Administrativas por Defecto en Script

ALTA

CATEGORÍA: A. Seguridad / F. Autenticación | ESTADO: Corregido

Descripción del Problema: El script de inicialización del administrador contenía correo y contraseña estáticos fijos utilizados si no se indicaban otros.

Manifestación: El despliegue del sistema nacía con una cuenta con privilegios máximos y contraseña universalmente conocida.

Riesgo o Impacto: Acceso no autorizado al backend con perfil de superusuario en entornos desplegados.

Detección: Revisión técnica de utilitarios de aprovisionamiento de datos.

Corrección Realizada: Exigencia estricta de variables de entorno para correo y contraseña administrativa, abortando si faltan.

Verificación: Prueba en suite de seguridad (Bloque 3), confirmando que el script aborta explícitamente sin variables.

Estado Actual: La cuenta inicial exige credenciales explícitas provistas por el operador de infraestructura.

INCIDENCIA 03 — Clave Secreta Insegura de Contingencia en WebSockets

CRITICA

CATEGORÍA: A. Seguridad / F. Autenticación | ESTADO: Corregido

Descripción del Problema: El intermediario de WebSockets utilizaba una clave de texto estática si la variable de entorno del secreto JWT no estaba definida.

Manifestación: Un atacante podía firmar sus propios tokens con la clave conocida y acceder al canal de eventos en tiempo real.

Riesgo o Impacto: Suplantación de identidad en eventos de cocina y salón, y acceso no autorizado a comandas.

Detección: Auditoría perimetral de canales de tiempo real.

Corrección Realizada: Eliminación del texto de respaldo; verificación estricta de la clave secreta y rechazo inmediato si falta.

Verificación: Suite de seguridad (Bloque 4), confirmando rechazo de tokens sin firma legítima o ante ausencia de clave.

Estado Actual: El canal WebSocket exige tokens legítimos firmados por la clave maestra del servidor.

INCIDENCIA 04 — Carencia de Salvaguarda contra Seed Destructivo en Producción

ALTA

CATEGORÍA: B. Integridad / A. Seguridad | ESTADO: Corregido

Descripción del Problema: El script de seed eliminaba masivamente las colecciones del restaurante sin comprobar el entorno de despliegue.

Manifestación: Una invocación accidental del comando en producción borraba instantáneamente la base de datos viva.

Riesgo o Impacto: Pérdida catastrófica e irreversible de datos operativos, pedidos y mesas del restaurante.

Detección: Análisis de riesgos de scripts de inicialización.

Corrección Realizada: Inserción de compuerta lógica que verifica el entorno y aborta de inmediato si se encuentra en producción.

Verificación: Suite de hardening (Bloque 2), comprobando la interrupción inmediata de la rutina destructiva.

Estado Actual: El comando de reinicio de base de datos se encuentra bloqueado de forma inviolable en producción.

INCIDENCIA 05 — Confianza en Importes Monetarios Enviados por el Cliente

CRITICA

CATEGORÍA: B. Integridad / A. Seguridad | ESTADO: **Corregido**

Descripción del Problema: El endpoint de pedidos aceptaba precios unitarios, subtotales y totales directamente desde el cuerpo de la petición.

Manifestación: Un cliente manipulado podía enviar platos con precio cero o total modificado, cobrando importes ínfimos.

Riesgo o Impacto: Pérdidas financieras directas para el restaurante, evasión de pagos y fraude contable.

Detección: Auditoría de integridad financiera y pruebas con peticiones adulteradas.

Corrección Realizada: Autoridad monetaria exclusiva en backend: consulta de precios en catálogo, snapshot histórico y cálculo algorítmico.

Verificación: Suite de pedidos (Bloque 3), comprobando que los precios del cliente son descartados y reemplazados por el catálogo.

Estado Actual: El backend calcula de forma determinista subtotales y totales; el cliente no tiene autoridad monetaria.

INCIDENCIA 06 — Admisión de Cantidades, Descuentos e Importes Negativos

ALTA

CATEGORÍA: D. Validaciones / B. Integridad | ESTADO: **Corregido**

Descripción del Problema: La comanda admitía cantidades menores a uno o valores negativos en descuentos, propinas y subtotales.

Manifestación: Ítems con cantidades negativas restaban el total de la cuenta o distorsionaban los ingresos del turno.

Riesgo o Impacto: Corrupción contable en caja y desajustes severos en reportes analíticos.

Detección: Pruebas de límites de frontera en pedidos.

Corrección Realizada: Restricciones de esquema a nivel de base de datos (mínimo 0) y validación en servicio exigiendo cantidad >= 1 y montos >= 0.

Verificación: Suite de pedidos (Bloques 1 y 4), confirmando rechazo sistemático con código 400 Bad Request.

Estado Actual: El sistema rechaza cualquier valor cuantitativo o monetario por fuera de los rangos válidos.

INCIDENCIA 07 — Asignación de Comandas a Mesas Inexistentes

MEDIA

CATEGORÍA: B. Integridad / D. Validaciones | ESTADO: **Corregido**

Descripción del Problema: Al crear un pedido con identificador de mesa no registrado, el sistema fallaba en cascada o creaba pedidos huérfanos.

Manifestación: Comandas creadas sin ubicación física en salón, imposibles de despachar por los camareros.

Riesgo o Impacto: Descoordinación en salón y registros huérfanos en la base de datos.

Detección: Pruebas de integración entre Pedidos y Mesas.

Corrección Realizada: Verificación previa en el repositorio de mesas; si no existe, se retorna inmediatamente código 404 semántico.

Verificación: Suite de pedidos (Bloque 2), confirmando que mesas inexistentes reciben exactamente el código 404 esperado.

Estado Actual: Ninguna orden puede crearse si la mesa no existe formalmente en el sistema.

INCIDENCIA 08 — Autorización Insuficiente por Rol (RBAC) en Pedidos

ALTA

CATEGORÍA: F. Autorización / A. Seguridad | ESTADO: Corregido

Descripción del Problema: Operaciones clave del comandero carecían de control granular de roles, permitiendo cruces indebidos de funciones.

Manifestación: Cocineros podían crear pedidos de salón; camareros podían consultar pedidos pendientes de cobro en caja.

Riesgo o Impacto: Violación del principio de mínimo privilegio y riesgo de fraude operacional.

Detección: Auditoría de seguridad y matriz de control de acceso.

Corrección Realizada: Aplicación estricta de middleware RBAC: creación para Camarero/Admin; cocción para Cocinero/Admin; cobro para Cajero/Admin.

Verificación: Suite de pedidos (Bloque 5), ejecutando peticiones cruzadas y comprobando rechazo con código 403 Prohibido.

Estado Actual: Cada operador está restringido exclusivamente a las operaciones propias de su perfil de trabajo.

INCIDENCIA 09 — Presencia de Estados Obsoletos ("SERVIDO", "Reservada")

MEDIA

CATEGORÍA: C. Errores Lógicos / G. Mantenimiento | ESTADO: Corregido

Descripción del Problema: Persistían estados obsoletos en filtros de consulta de pedidos ("SERVIDO") y en el modelo de mesa ("Reservada").

Manifestación: Consultas con condiciones muertas y posibilidad de estados zombi en la base de datos.

Riesgo o Impacto: Ambigüedad en máquinas de estado y código confuso ante auditorías.

Detección: Auditoría post-eliminación del módulo de reservas.

Corrección Realizada: Depuración integral: estados de Mesa fijados en Libre, Ocupada y Cuenta Solicitada; Pedidos fijados en 5 estados oficiales.

Verificación: Suite de pedidos (Bloque 0) e inspección estática exhaustiva en todo el directorio fuente.

Estado Actual: El modelo de dominio refleja exclusivamente los estados válidos y operativos del restaurante.

INCIDENCIA 10 — Controladores Monolíticos y Acoplamiento en Pagos y Dashboard

ALTA

CATEGORÍA: E. Arquitectura | ESTADO: Reestructurado

Descripción del Problema: Los controladores de Pagos y Dashboard concentraban cientos de líneas mezclando lógica de negocio y consultas directas a base de datos.

Manifestación: Imposibilidad de probar la lógica de cobro y métricas sin levantar el servidor Express.

Riesgo o Impacto: Deuda técnica severa, fragilidad ante cambios y nula testabilidad unitaria.

Detección: Auditoría de arquitectura y métricas de complejidad ciclomática.

Corrección Realizada: Extracción completa a Servicios y Repositorios dedicados; controladores reducidos a simples intermediarios HTTP.

Verificación: Suites de pruebas independientes para repositorios, servicios y controladores de Pagos y Dashboard.

Estado Actual: Ambos módulos cumplen con el estándar arquitectónico desacoplado de seis capas.

INCIDENCIA 11 — Acoplamiento Directo a Modelos en Inventario y Contador

MEDIA

CATEGORÍA: E. Arquitectura | ESTADO: **Reestructurado**

Descripción del Problema: Los servicios de Inventario y Contador interactuaban directamente con esquemas Mongoose sin capa de abstracción.

Manifestación: Cualquier modificación en la persistencia obligaba a modificar la lógica de negocio de stock y correlativos.

Riesgo o Impacto: Rigidez estructural y fragilidad del código ante refactorizaciones.

Detección: Revisión de cumplimiento del patrón Repositorio en fases 14.1 y 14.2.

Corrección Realizada: Creación de InventarioRepository y ContadorRepository dedicados con inyección de dependencias en los servicios.

Verificación: Suites unitarias y de integración para Inventario y Contador con base de datos real.

Estado Actual: El acceso a datos en ambos módulos se encuentra completamente abstraído.

INCIDENCIA 12 — Presencia de Módulos Huérfanos y Código Residual

MEDIA

CATEGORÍA: G. Mantenimiento / Código Residual | ESTADO: **Eliminado**

Descripción del Problema: Permanecían archivos y rutas de módulos discontinuados (Delivery, Clientes externos, Códigos telefónicos, Google OAuth).

Manifestación: Superficie de ataque extendida, advertencias en compilación y dependencias innecesarias en el proyecto.

Riesgo o Impacto: Confusión en mantenimiento y riesgo de reactivación accidental de código no auditado.

Detección: Auditoría de código huérfano y análisis de rutas activas.

Corrección Realizada: Eliminación definitiva de controladores, modelos y rutas huérfanas; purga de dependencias en package.json.

Verificación: Compilación limpia con tsc y auditoría de árbol de dependencias.

Estado Actual: El repositorio contiene exclusivamente los componentes operativos del restaurante.

INCIDENCIA 13 — Riesgo de Condiciones de Carrera en Asignación de Correlativos

MEDIA

CATEGORÍA: B. Integridad / C. Errores Lógicos | ESTADO: **Corregido**

Descripción del Problema: La lectura y actualización de correlativos PED-XXXX se realizaba en pasos separados sin garantía de atomicidad concurrente.

Manifestación: Comandas simultáneas en distintas mesas podían recibir el mismo número secuencial.

Riesgo o Impacto: Colisión de identificadores únicos y rechazo de persistencia de comandas activas.

Detección: Análisis de concurrencia y pruebas de estrés sobre la generación secuencial.

Corrección Realizada: Implementación de operaciones atómicas con incremento en una única transacción de base de datos.

Verificación: Suite de pruebas de contador (Bloque B), verificando consistencia bajo llamadas concurrentes continuas.

Estado Actual: La generación secuencial es atómica, inmutable y libre de colisiones.

INCIDENCIA 14 — Discrepancia de Tipado en Números de Mesa en Seed

BAJA

CATEGORÍA: D. Validaciones / B. Integridad | ESTADO: **Corregido**

Descripción del Problema: El script de seed insertaba identificadores de mesa como números enteros, mientras el modelo requería cadenas de texto.

Manifestación: Inconsistencias al filtrar mesas o desajustes de tipo en pruebas automatizadas.

Riesgo o Impacto: Fallas menores en filtros de salón y desalineación con la especificación de la API.

Detección: Inspección de scripts de base de datos y pruebas de mesas.

Corrección Realizada: Estandarización del formato a cadena de texto en el script de seed y validación de tipos consistente.

Verificación: Ejecución limpia del seed y ejecución exitosa de la suite de mesas.

Estado Actual: El formato de identificadores de mesa es homogéneo en toda la pila tecnológica.

4. Auditoría Temática de Seguridad y Autenticación

La seguridad perimetral e interna del backend se fortaleció en múltiples frentes: erradicación total de credenciales en código fuente (EmailJS, administradores por defecto, claves de socket), implementación de autenticación sin estado gobernada por tokens JWT con expiración estricta y blindaje contra ejecución destructiva de scripts en entornos productivos.

5. Auditoría de Pedidos y Autoridad Monetaria

El backend asume la Autoridad Monetaria Absoluta: el cliente solo envía identificadores de platos y cantidades enteras positivas. El servidor consulta el catálogo oficial, genera snapshots históricos inmutables de precio por comanda, calcula subtotales y total general, y rechaza montos negativos de propinas o descuentos con código 400.

6. Auditoría del Ciclo de Vida de Mesas

El salón opera bajo una máquina de tres estados deterministas (Libre, Ocupada, Cuenta Solicitada). Las transiciones se encuentran automatizadas al crear pedidos, solicitar cuentas y confirmar pagos, habiéndose desvinculado por completo de reservas.

7. Retiro del Módulo de Reservas y Saneamiento

Como decisión de negocio orientada al servicio presencial en tiempo real, se eliminó de raíz el módulo de reservas (controladores, modelos, rutas, repositorios y servicios), purgando más de 630 líneas de código y verificando la ausencia de referencias residuales en el resto de los módulos.

8. Refactorización Arquitectónica Multicapa

La totalidad de los módulos fue reorganizada bajo el patrón formal de seis capas (Ruta -> Middleware -> Controlador -> Servicio -> Repositorio -> Modelo). Esto permitió adelgazar controladores monolíticos (Pagos y Dashboard) y aislar la infraestructura de base de datos mediante repositorios dedicados.

9. Endurecimiento de Validaciones Perimetrales

Se implementó la estrategia Fail-Fast: las solicitudes inválidas son interceptadas en la entrada con respuestas 400 Bad Request normalizadas, complementadas con restricciones de esquema a nivel de base de datos (mínimo 0 en montos y mínimo 1 en cantidades).

10. Control de Acceso Basado en Roles (RBAC)

Se consolidó una matriz de privilegios mínimos para los cuatro roles operativos del restaurante:

Módulo Funcional	Administrador	Camarero	Cocinero	Cajero
Usuarios y Cuentas	Total (CRUD)	Prohibido	Prohibido	Prohibido
Mesas de Salón	Total (CRUD)	Consulta y Estado	Solo Consulta	Solo Consulta
Catálogo de Platos	Total (CRUD)	Solo Consulta	Solo Consulta	Solo Consulta
Recetas e Insumos	Total (CRUD)	Prohibido	Solo Consulta	Prohibido
Almacenes y Stock	Total (CRUD)	Prohibido	Consulta Stock	Prohibido
Comandero (Pedidos)	Total	Crear y Servir	Preparación	Consulta Cobro
Módulo de Pagos	Auditoría	Prohibido	Prohibido	Cobro y Cierre
Dashboard Analítico	Total	Prohibido	Prohibido	Prohibido
Contador Secuencial	Auditoría	Sistema	Sistema	Sistema

11. Base de Datos y Consistencia Transaccional

La persistencia asegura consistencia estricta: incremento atómico en correlativos diarios (PED-XXXX), verificación de precondiciones antes de inserciones y preservación histórica mediante bajas lógicas para auditoría.

12. Módulo de Pagos y Liquidación Financiera

La liquidación en caja exige coincidencia matemática exacta entre el monto pagado y el total del pedido, soporta métodos auditables (EFECTIVO, TARJETA, TRANSFERENCIA) y ejecuta el cierre atómico del pedido y la liberación inmediata de la mesa.

13. WebSockets y Comunicación en Tiempo Real

El servidor de sockets implementa autenticación obligatoria en el handshake contra la clave maestra, organiza las conexiones en salas temáticas y emite notificaciones instantáneas tras cada mutación de comanda o pago.

14. Evidencia de Pruebas y Suites de Regresión

Las correcciones implementadas se encuentran validadas mediante suites de pruebas automatizadas con resultados 100% satisfactorios:

Suite de Prueba Especializada	Área Funcional Evaluada	Casos	Resultado
test_fase_14_6_pedidos.cjs	Cálculo seguro, snapshot, montos y RBAC	18	100% Superado
test_fase_14_3_seguridad.cjs	Variables de entorno, EmailJS y sockets	8	100% Superado
test_fase_14_2_contador.cjs	Atomicidad de correlativos secuenciales	6	100% Superado
test_fase_14_1_inventario.cjs	Desacoplamiento de stock y repositorios	9	100% Superado
test_fase_13_3_dashboard.cjs	Servicio de agregación y métricas	7	100% Superado
test_fase_12_5_pagos.cjs	Descuentos, propinas y cierre de mesa	13	100% Superado
test_mesa_module.cjs	Máquina de estados de salón y validaciones	11	100% Superado
test_plato_module.cjs	Catálogo de platos y disponibilidad	8	100% Superado

Suite de Prueba Especializada	Área Funcional Evaluada	Casos	Resultado
test_usuario_module.cjs	Gestión de colaboradores y autenticación	10	100% Superado

15. Cronología de Commits y Refactorizaciones

Hitos históricos registrados en el repositorio institucional de software:

Commit	Fecha	Área Afectada	Hito de Ingeniería Alcanzado
1ff5fbf	27/09/2026	Arquitectura Global	Estandarización multicapa y retiro de módulos huérfanos.
000701a	27/09/2026	Módulo Pagos	Definición de interfaces y preparación estructural de pagos.
6ed35a8	27/09/2026	Módulo Pagos	Creación e implementación desacoplada del servicio de pagos.
1948adb	27/09/2026	Módulo Pagos	Adelgazamiento del controlador de pagos y extracción de reglas.
c0c96af	27/09/2026	Dashboard	Tipado formal e interfaces para métricas ejecutivas.
8956c6f	27/09/2026	Dashboard	Repositorio analítico desacoplado de la infraestructura.
bc84bfc	27/09/2026	Dashboard	Servicio de agregación y cálculo del tablero analítico.
9507bc1	27/09/2026	Dashboard	Controlador de dashboard simplificado a intermediario HTTP.
0185166	27/09/2026	Inventario	Desacoplamiento del servicio de inventario de modelos Mongoose.
fc5b0d5	27/09/2026	Contador	Atomicidad en generación de secuencias y desacoplamiento.
312d45c	27/09/2026	Seguridad	Hardening: variables de entorno, EmailJS y sockets.
462607d	27/09/2026	Limpieza	Purga de código huérfano, dependencias no utilizadas y stubs.
a1edce2	27/09/2026	Reservas	Retiro definitivo del módulo de reservas y estados residuales.
Fase 14.6	30/09/2026	Pedidos	Autoridad monetaria, snapshot de precios y validaciones RBAC.

16. Tabla Resumen de Incidencias Catalogadas

ID	Cat.	Problema Detectado	Sev.	Corrección Implementada	Estado
01	Seg.	Credenciales EmailJS en código	Crítica	Variables de entorno obligatorias	Corregido
02	Seg.	Contraseña admin por defecto	Alta	Variables obligatorias en script	Corregido
03	Seg.	Secreto de contingencia socket	Crítica	Eliminación de fallback y token JWT	Corregido
04	Seg.	Seed destructivo en producción	Alta	Compuerta bloqueando modo prod	Corregido
05	Integ.	Precios fijados por cliente	Crítica	Autoridad monetaria en backend	Corregido
06	Valid.	Montos y cantidades negativas	Alta	Restricciones de esquema y servicio	Corregido
07	Integ.	Pedidos sobre mesas inexistentes	Media	Validación previa con error 404	Corregido
08	Autz.	Permisos cruzados sin rol	Alta	RBAC granular por endpoint	Corregido
09	Lóg.	Estados obsoletos en modelos	Media	Máquinas de estado estandarizadas	Corregido

ID	Cat.	Problema Detectado	Sev.	Corrección Implementada	Estado
10	Arq.	Controlador monolítico pagos/dash	Alta	Desacoplamiento en Servicios y Repos	Reestructurado
11	Arq.	Servicios acoplados a modelos	Media	Repositorios con inyección de deps	Reestructurado
12	Mant.	Módulos huérfanos residuales	Media	Purga integral de código muerto	Eliminado
13	Integ.	Condiciones de carrera contador	Media	Incremento atómico en base de datos	Corregido
14	Valid.	Discrepancia tipo número mesa	Baja	Estandarización a string en seed	Corregido

17. Análisis del Estado Actual del Backend

Las intervenciones realizadas transformaron el backend en una plataforma predecible, segura y mantenible. Se cuenta con:

- **Secretos Protegidos:** Cero credenciales en texto plano; variables de entorno estrictas y documentadas.
- **Autoridad Financiera Algorítmica:** Cálculo inviolable de subtotales, totales y snapshots históricos por comanda.
- **Separación de Responsabilidades:** Arquitectura desacoplada en seis capas con 100% de controladores delgados.
- **Regresión Superada:** Suites automatizadas con 100% de éxito y compilación de TypeScript limpia.

Declaración de Responsabilidad Técnica

Ningún software es absolutamente invulnerable. Sin embargo, las incidencias lógicas, financieras y perimetrales identificadas durante las auditorías fueron exhaustivamente resueltas y verificadas.

18. Conclusiones y Lecciones de Ingeniería

El proceso de refactorización demostró que la seguridad y la consistencia de datos deben integrarse como principios rectores de diseño. La erradicación de la autoridad financiera en el cliente, la segregación de funciones mediante RBAC y la abstracción mediante repositorios proporcionan al establecimiento una plataforma sólida y preparada para la operación continua.